Monthly Intelligence Dispatch

June 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB revealed the identity of a hacker hiding under the nickname "**Fxmsp**", who is believed to be one of the most prolific sellers of access to company networks.
- **Google** saw an increase in attacks conducted by state-sponsored hacker groups.
- Human rights activists at **Amnesty International** reported a new attack using **Pegasus** spyware developed by Israeli cybersecurity company **NSO Group**.
- A malicious campaign involving **Loki PWS** was disguised as an email from the Minister of Health of Kazakhstan related to receiving government aid during the pandemic.
- Japanese car-maker giant **Honda** fell victim to the **Ekans** ransomware. Attackers disrupted both the customer service and financial services operations, as well as encrypted the company's internal network, including mail servers.
- A group of hacktivists known as Distributed Denial of Secrets (DDoSecrets) published a 269-gigabyte collection of data belonging to U.S. law enforcement agencies and fusion centers.
- Large banks tracked an increase in the activity of scammers creating cloned websites masqueraded as official resources of credit organizations.

Fxmsp

In June 2020, Group-IB released an analytical report Fxmsp: "The Invisible God of Networks“, which revealed the presumed identity of a hacker hiding under the nickname "Fxmsp". This threat actor, who is believed to be one of the most notorious sellers of access to company networks, had been providing his services on underground forums for about three years.

Group-IB Threat Intelligence helped determine the type of tools Fxmsp used to compromise company networks and establish the exact number of victims and his presumed identity with a high degree of probability. Group-IB's report describes how, according to conservative estimates, the Russian-speaking hacker Fxmsp made at least $1.5 million throughout his operations in less than 3 years step by step. The data provided in the report represented the low-range estimate, since it only took into account public lots offered by the cybercriminal without taking into account sales Fxmsp had made through private messages, lots without an indication of the price, or repeated sales of access to the same companies.

Fxmsp’s early posts indicate that he initially had little knowledge about how to monetize the access and maintain persistence within the networks he had compromised. He was asking around about self-propagating persistent cryptomining malware and other Trojans for infecting corporate networks seeking for help with accesses he had gained, making a number of mistakes along the way.

Fxmsp worked together with his accomplice with the nickname **Lampeduza**, who was in charge of marketing and monetizing accesses and data. From October 2017 to September 2019, they put access to 135 companies from 44 countries (e.g. the USA, Russia, the UK, France, Italy, the Netherlands, Singapore, Japan, Australia) up for sale. Russian hackers have an unspoken rule about not working within Russia and CIS countries. Fxmsp violated this rule by attempting to sell accesses to two Russian companies, after which he was banned from the forum, which, however, did not stop the criminal.

Fxmsp’s victims were mainly companies in the light industry. His second most common targets were companies offering IT services. Four companies attacked by Fxmsp were included in the Fortune Global 500 ranking in 2019. Fxmsp’s victims also included banks, telecommunications companies, and the fuel and energy sector. One of the energy companies was hit by a ransomware attack in the summer of 2020. Group-IB shared detailed information about Fxmsp with international law enforcement.

DDoSecrets	The DDoSecrets hacktivist group released a 269-gigabyte collection of data belonging to police departments and law enforcement fusion centers across the United States. The leak, **collectively called** "BlueLeaks," contains more than one million files such as scanned documents, videos, emails, audio files, and more. DDoSecrets claims the leaked files belong to more than **200** police departments and law enforcement fusion centers. Most of the files are police and FBI reports, security bulletins, and law enforcement guides. Some of the files also supposedly contain sensitive and personal information, such as names, bank account numbers, and phone numbers. DDoSecrets claims it received the BlueLeaks data "courtesy of Anonymous," the infamous hacktivist group.
Pegasus	Researchers at **Amnesty International** reported a new case of using NSO Group's Pegasus cyber spyware. Amnesty International identified evidence of attacks on **Omar Radi**, an activist and journalist from Morocco, from January 2019 until the end of January 2020. His iPhone was compromised either using a device commonly referred to as a "IMSI Catcher" (a fake base station) or by leveraging access to the victim's mobile operator to redirect Radi's HTTP traffic to a resource controlled by the attackers. The malicious infrastructure belongs to **NSO Group**, Amnesty International reports.
Spectre	A hacker with the nickname "spectre" approached researchers at Cyble Inc. (USA) to inform them that he/she was selling confidential military data belonging to the Indian Government on the dark web for 25 BTC. **Cyble**'s investigation futher confirmed the veracity of scanned copies of sensitive documents. In early June, the same threat actor claimed the responsibility for stealing data from Indian military contractor BEML. Initially, researchers suspected a Pakistani hacktivist called "R3dr0x" to have been behind this leak. Spectre is said to be the same actor who was presumably selling classified documents belonging to the Turkish authorities.

TA410	Researchers at **Proofpoint** released a report on cyber operations against the U.S. energy sector. The attacks on US-based energy providers were reportedly conducted by a government-sponsored group dubbed TA410 between July-November 2019. The phishing campaigns impersonated the American Society of Civil Engineers (ASCE) to deliver **LookBack and FlowCloud Remote Access Trojans (RATs).** It is interesting to note that although some of the TTPs indicate similarities between TA410 and the Chinese group **APT10 (Stone Panda)**, Proofpoint is not sure whether Stone Panda was behind the phishing attacks—the possibility remains that these overlaps represent false flag activity by the TA410 threat actor.
Google vc APT	**Google** said it saw a resurgence in hacking attempts conducted by state-sponsored groups. Security experts at Alphabet Inc's Google sent **1,755** warnings in April to users whose accounts were targets of government-backed attackers. Google said on Wednesday its **Threat Analysis Group** saw new activity from "hack-for-hire" firms, many based in India, that have been creating Gmail accounts spoofing the **World Health Organization (WHO).**
Telegram	A database containing the personal data of millions of users of the messaging app Telegram was posted on a darknet forum. The leak contains phone numbers, unique Telegram user IDs, and nicknames belonging to users based in Russia and Iran. Marketing and advertising agencies often use bots to collect such information for commercial purposes. Law enforcement agencies and cybercriminals can also be interested in this type of information. The database file is about **900 megabytes**.

The COVID-19 pandemic has created new opportunities for cybercrime worldwide, therefore the number of coronavirus-themed attacks continues to increase. Attackers have started actively using old vulnerabilities along with new social engineering techniques to infect IoT devices.

Researchers have tracked a resurgence of botnets such as Mirai, which are used to attack various companies around the globe.

COVID-19

Attacks have to become more sophisticated and organized as trillions of dollars and countries' geopolitical reputation are set on stake.

For example, against the background of the introduction of new restrictive measures in **Kazakhstan**, where Kazakhstan's former president, Nursultan Nazarbayev, tested positive for coronavirus, in June cybercriminals carried out a malicious campaign disguised as an ordinance from the Minister of Health of the Republic of Kazakhstan. The emails inform about the possibility to obtain protective equipment for free as part of the government's support during the coronavirus pandemic. Recipients were prompted to fill out the attached form and send it back.

According to **CERT-GIB** analysts, the attachment contained malicious documents that installed a variant of the Loki PWS malware family designed to steal credentials from an infected computer. The stolen data is automatically sent to attackers, and can be either sold on hacker forums or used to gain access to email accounts for financial fraud or espionage purposes.

Ryuk
DoppelPaymer
REvil

After a relatively quiet 2018, ransomware was back with a vengeance in 2019: ransomware attacks increased 40% over the last year, according to Group-IB's study "Ransomware Uncovered: Attackers' Latest Methods." The year of 2019 was marked by ransomware operators shifting to larger targets such as municipalities, corporations and healthcare facilities, which determined greater ransoms — the average figure soared from $8,000 in 2018 to $84,000 last year. According to Group-IB's Digital Forensics Lab, the most aggressive and greediest ransomware families with highest pay-off were apparently Ryuk, DoppelPaymer and REvil, the latter on occasion demanding $800,000. As the tactics and tools used by ransomware operators have evolved to the sophisticated techniques reminding those typical of APT groups, and the corporate sector has become ransomware operators' key target, this year they are likely to celebrate with even greater achievements in terms of the number of attacks and the amount of financial damage.

Maze

In June 2020, operators of Maze, one of the most aggressive ransomware, published a list of more than **10** companies whose resources they had allegedly compromised. The list includes firms located in the USA, Macedonia, Brazil, and the United Arab Emirates, as well as one Brazilian government website. In early June, Maze attacked **Westech International**, a US defense contractor. The Maze ransomware operators not only encrypted the contractors' files but also exfiltrated them. Confirmations of the leak have been posted online. The Maze ransomware attack is likely to have significant implications given that Westech International is responsible for the maintenance of the U.S. arsenal of Minuteman III land-based intercontinental ballistic missiles. What's worth mentioning is that Maze started cooperating with two other ransomware, which created a so-called "**Maze Cartel**". The website designed to leak Maze victims' data now also contains files and other information stolen by **LockBit** and **Ragnar Locker** ransomware operators. Researchers at Singapore-based **Cyfirma** claim that APT 28 (aka Fancy Bear) and APT 29 (aka Cozy Bear or the Dukes) are behind Maze ransomware.

Major events: Ransomware

Ekans

Operations at the Japanese car manufacturer **Honda** were disrupted by an attack using **Ekans** ransomware. Attackers disabled customer service and financial services networks, and encrypted the internal network, including mail servers. What's worse, the cyberattack also affected Honda's production systems outside of Japan. A security researcher named Milkream found a sample of the Ekans ransomware that checks for the internal Honda network name of "mds.honda.com" to start. Ekans aka SNAKE has only been around since about December 2019. The ransomware is believed to be primarily targeting industrial control systems.

DopplePaymer

Operators of the DopplePaymer ransomware congratulated SpaceX and **NASA** for their first successful human-operated rocket launch in an unusual manner. The attackers announced that they had infected the network of one of NASA's IT contractors, **Digital Management Inc. (DMI**), a US-based company. The DopplePaymer gang posted part of the NASA-related data exfiltrated from 2,583 servers and workstations belonging to DMI's internal network, which they had encrypted for ransom.

Black Kingdom

REDTEAM.PL, a Poland-based security services company, found operators of **Black Kingdom** ransomware were targeting enterprises with unpatched Pulse Secure VPN software. They're exploiting **CVE-2019-11510**, a critical vulnerability that was patched in April 2019. Many companies, however, have delayed updating the software, which can result in serious financial losses for them. It's worth reiterating that in May 2020, the UK power grid middleman **Elexon** had its servers infected with **Sodinokibi** (REvil) ransomware after as a result of a cyberattack. Researchers stated that the company was using an outdated version of Pulse Secure VPN which may have been exploited.

Evil Corp

Fox-IT experts reported that the infamous hacker group Evil Corp resumed their activity with new tools in the spring of 2020. According to the researchers, a new WastedLocker ransomware developed by the group has been used exclusively against U.S.-based companies, and the amount that Evil Corp demands from their victims in ransom now amounts to millions of dollars. For example, researchers know a case where hackers demanded $10,000,000 from a company.

Evil Corp, also known as Dridex, has been active since 2007. Their initial efforts were focused on distributing the Cridex banking Trojan, a malware strain that later evolved into the Dridex banking Trojan. Across the years, Evil Corp, through its Dridex operation became operators of one of the largest malware and spam botnets. The group dipped their toes into ransomware distribution by spreading the Locky ransomware to home consumers throughout 2016. Further the group shifted their focus from home consumers to enterprise targets. After the unsealing of indictments by the US Department of Justice against Evil Corp, the group remained inactive until January 2020. However, since January 2020 they resumed activity by conducting several attacks.

Bitcoin Revolution

In June 2020, a joint investigation of Group-IB's teams uncovered a sophisticated three-stage SMS fraud designed to drag users based in 23 countries into a shady bitcoin investment scheme. Group-IB experts initially discovered a targeted SMS campaign against crypto investors in Singapore. The scheme is similar to the "Bitcoin Revolution" scam that Group-IB reported in February 2020. Back then Group-IB discovered a network of 18 active fake resources aimed at tricking users from Singapore into visiting a shady bitcoin investment page. The scammers leveraged fake websites posing as Singapore media outlet, the Straits Times. Users were asked to provide their personal data: first name, last name, email address, and phone number. The main difference of the newly discovered scheme is that the threat actor used text messages to distribute links to fraudulent resources. An analysis of the exposed phone country codes showed that most of the victims were from the UK (164,318), followed by Australia (88,443), South Africa (4,461), the US (4,208), Singapore (3,499), and other countries.

Oblivion0o

Since late May 2020, a user with the nickname "Oblivion0o" has started selling access to banks' networks on the forum xss.is. At the time of writing, all accesses are related to banks in Southeast Asia, Asia, and Africa. According to the ad, the attacker sells access with administrator privileges and the access level not lower than "Account Manager". Lot prices range from 150 to 350 euros. The criminal also says that they provide services for delivering payloads to banks' networks.

Silent & Macro

Group-IB experts found an ad about the sale of an exploit kit for Microsoft Excel that was published by a user with the nickname "Solmyr" on the underground forum Exploit.in. The exploit kit consists of the two exploits Silent and Macro combined into one file. According to the seller, the Silent exploit targets the 1-day vulnerability CVE-2017-11882 and affects almost all versions of Microsoft Office, while the Macro exploit runs on all Microsoft Office versions. CVE-2017-11882 is a remote code execution (RCE) vulnerability that exists in Microsoft Office software when it fails to properly handle objects in memory. The vulnerability is exploited when a user opens a specially crafted file on an vulnerable version of Microsoft Office. An attacker can convince a user to open a file sent as an email attachment that contains specially crafted content to exploit this vulnerability. This will allow an attacker to run arbitrary code in the context of the current user. The seller noted that the license to use this exploit kit was valid for one month. The license cost was **USD 1,250**. Solmyr highlighted that they released updates for the software regularly on Wednesdays and Sundays.

-

Arrests and sentences

SIM

With the assistance from Group-IB, Russian law enforcement arrested the organizers of a criminal group that focused on reissuing SIM cards and stealing money from Russian banking customers. The group had been active for several years; wealthy people, even those confined in places of detention, were among their victims. During the search, the police found a large number of SIM cards, laptops, smartphones and feature phones, as well as fake IDs, such as passports, driving licenses and payment cards, to which the stolen money was transferred, along with SIM cards linked to these cards. To store confidential data, the criminals used encrypted USB drives. The detainees confessed to the fraud. As a result, criminal proceedings have been initiated in accordance with the Russian Criminal Code (Article 159).

Brian Kil

According to Motherboard, **Facebook** helped the FBI hack one of its users who was using the social media platform to commit crimes. For years, Buster Hernandez of California, who was known as "Brian Kil" online, harassed and terrorized young girls, extorting them for nude photos and videos and threatening to kill and rape them. The FBI had reportedly been searching for Buster Hernandez for years. Facebook paid a cybersecurity consulting firm to develop a hacking tool that could infiltrate the privacy-focused Tails OS to reveal the criminal's real IP address. This activity ultimately led to the criminal being arrested.

Forecasts and warnings

- Ransomware operators use tactics, techniques, and procedures (TTPs) typical of APT groups (e.g. before encrypting information, they exfiltrate data important to the victim).
- Cybercriminals often use the Dridex, Emotet, SDBBot, and Trickbot banking Trojans to initially compromise target networks.
- Most ransomware operators use tools that are employed by cybersecurity specialists during penetration tests (e.g. Cobalt Strike, CrackMapExec, PowerShell Empire, PoshC2, and Metasploit).
- More and more cybercriminals offer ransomware as a Ransomware-as-a-Service (RaaS) service to sell or rent it in exchange for part of the ransom.
- The Telegram user database that was leaked on the darknet contains phone numbers, unique Telegram user IDs and nicknames. Knowing a nickname and phone number, you can identify the user's real identity. With user IDs in hand, you can retrospectively analyze the nicknames, phone numbers, and other registration data.
- Criminals can use credentials from personal accounts or bank card data obtained through phishing either to steal money or to resell stolen data on underground forums to other cybercriminals. The credentials can be subsequently used in various criminals schemes ranging from phone fraud to extortion.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com